

AD02 – Manual de Operaciones de la Autoridad de Registro (AR)

ID Documento: GOYA-AD02-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Confidencial **Proximo revision:** 2027-03-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Oficial de Seguridad	Documento inicial

1. Control del Documento

1.1 Responsabilidad del documento

Rol	Responsabilidad
Oficial de Seguridad	Redaccion, revision periodica y mantenimiento del manual
Gerente de Operaciones AR	Validacion de procedimientos operativos y flujos de trabajo
Gerente General	Aprobacion formal y autorizacion de distribucion
Auditor Interno	Verificacion de alineamiento con EA-103 y normativa vigente
Asesor Juridico	Revision de conformidad legal con Ley 19.799 y DS 181/2002

1.2 Lista de distribucion

Destinatario	Tipo de Copia	Medio
Gerencia General	Controlada	Sistema documental interno
Gerente de Operaciones AR	Controlada	Sistema documental interno
Oficial de Seguridad	Controlada	

Destinatario	Tipo de Copia	Medio
		Sistema documental interno
Operadores AR	Controlada	Sistema documental interno
Auditor Interno	Controlada	Sistema documental interno
Entidad Acreditadora (Subsecretaria de Economia)	No controlada	Entrega bajo solicitud formal

1.3 Dependencias documentales

Documento	ID	Relacion con este manual
Plan de Gestion de Riesgos	GOYA-PS01-001	Riesgos operacionales de la AR y controles mitigantes
Politica de Seguridad	GOYA-PS02-001	Controles fisicos y logicos aplicables a oficinas y sistemas AR
Plan de Continuidad del Negocio	GOYA-PS03-001	Procedimientos de contingencia para indisponibilidad de servicios AR
Plan del SGSI	GOYA-PS04-001	Marco de gestion de seguridad de la informacion para la AR
Autoevaluacion de Cumplimiento	GOYA-PS05-001	Auditorias periodicas de procesos AR
Plan de Administracion de Llaves	GOYA-PS06-001	Ciclo de vida de llaves generadas en la AR
Plan de Cese de Actividades	GOYA-PS07-001	Procedimientos de cierre aplicables a la AR
Modelo Operacional AC	GOYA-PO03-001	Interfaz operativa AR-AC, flujo de CSR y revocacion
Modelo Operacional AR	GOYA-PO04-001	Modelo de referencia que este manual operacionaliza
Manual de Operaciones AC	GOYA-AD01-001	Procedimientos de la AC con los que la AR interactua
Politica de Certificados FEA	GOYA-PO01-001	Politica de nombres, validez y usos de certificados
Declaracion de Practicas de Certificacion (CPS)	GOYA-CPS-001	Practicas declaradas que la AR implementa operativamente

1.4 Definiciones y acronimos

Termino	Definicion
AR	Autoridad de Registro
AC	Autoridad de Certificacion
PSC	Prestador de Servicios de Certificacion
FEA	Firma Electronica Avanzada
FES	Firma Electronica Simple
SSCD	Secure Signature Creation Device
QSCD	Qualified Signature Creation Device
LoA	Level of Assurance (nivel de aseguramiento)
DID	Identificador Descentralizado (Decentralized Identifier)
CSR	Certificate Signing Request
CRL	Certificate Revocation List
OCSP	Online Certificate Status Protocol
RUT	Rol Unico Tributario
SII	Servicio de Impuestos Internos
PKCS#12	Formato de intercambio de informacion personal (llaves + certificados)

2. Dotacion de Personal

2.1 Estructura organizacional de la AR

Rol	Cantidad minima	Reporta a
Gerente de Operaciones AR	1	Gerente General
Operador AR	2	Gerente de Operaciones AR
Oficial de Seguridad	1	Gerente General
Auditor Interno	1	Gerente General (independiente de linea operativa)

2.2 Responsabilidades por rol

Gerente de Operaciones AR:

1. Supervisar la ejecucion de procedimientos de verificacion de identidad.

2. Aprobar excepciones operativas documentadas en el registro de incidencias.
3. Coordinar la interaccion AR-AC conforme a GOYA-PO03-001.
4. Asegurar la disponibilidad de personal capacitado en todas las oficinas AR.
5. Revisar y actualizar procedimientos operativos semestralmente.
6. Autorizar la suspension y revocacion de certificados a solicitud de suscriptores.

Operador AR:

1. Ejecutar la verificacion de identidad presencial y por videoconferencia.
2. Operar el sistema de verificacion remota (Smart-ID, UAE Pass).
3. Registrar solicitudes de certificado en el sistema mediante POST /api/v1/certificates/fea.
4. Capturar evidencia biometrica conforme a ISO 19794-2.
5. Custodiar documentacion de verificacion durante el periodo de retencion (15 años, DS 181 Art. 25).
6. Escalar incidencias al Gerente de Operaciones AR.

Oficial de Seguridad:

1. Auditar el cumplimiento de los procedimientos de este manual.
2. Gestionar incidentes de seguridad conforme a GOYA-PS07-001.
3. Administrar los controles de acceso logico a los sistemas AR.
4. Ejecutar revisiones periodicas de bitacoras de operacion.
5. Proponer actualizaciones al presente manual basadas en hallazgos de auditoria.

Auditor Interno:

1. Realizar auditorias semestrales de los procesos AR.
2. Verificar la conformidad con EA-103 seccion 4.22.
3. Emitir informes de auditoria con hallazgos clasificados por severidad.
4. Validar la efectividad de acciones correctivas implementadas.
5. Mantener independencia funcional respecto a la linea operativa AR.

2.3 Requisitos de capacitacion

Capacitacion	Frecuencia	Destinatarios	Duracion minima
Procedimientos de verificacion de identidad	Inicial + anual	Operadores AR	16 horas
Normativa legal (Ley 19.799, DS 181, eIDAS)	Inicial + anual	Todos los roles AR	8 horas
Operacion del sistema de certificacion	Inicial + semestral	Operadores AR, Gerente Ops AR	12 horas
Seguridad de la informacion (ISO 27001)	Anual	Todos los roles AR	8 horas
Deteccion de documentos fraudulentos	Inicial + anual	Operadores AR presenciales	8 horas
	Semestral	Todos los roles AR	4 horas

Capacitacion	Frecuencia	Destinatarios	Duracion minima
Procedimientos de contingencia (GOYA-PS03-001)			
Criptografia post-cuantica y ML-DSA-65	Inicial	Gerente Ops AR, Oficial de Seguridad	4 horas

El registro de capacitacion se mantiene en el sistema documental interno con evidencia de asistencia y evaluacion de conocimientos. Ningun operador AR puede ejecutar verificaciones de identidad sin haber completado la capacitacion inicial y la evaluacion correspondiente con nota minima de 80%.

2.4 Separacion de funciones

Las siguientes combinaciones de funciones estan prohibidas en una misma persona:

Funcion A	Funcion B	Razon
Operador AR (verificacion)	Emisor de certificados (AC)	Impedir que quien verifica tambien emita
Operador AR (verificacion)	Auditor Interno	Impedir autoauditoria
Gerente de Operaciones AR	Auditor Interno	Garantizar independencia de auditoria
Operador AR (revocacion)	Operador AR (verificacion del mismo suscriptor)	Separacion entre registro y revocacion

La separacion de funciones se implementa mediante roles en el sistema de control de acceso (ACL). Cada operador AR posee credenciales individuales con permisos asignados segun su rol. Los permisos se configuran mediante ACL_MODE conforme a GOYA-PS02-001.

3. Procedimiento de Registro de Suscriptores

3.1 Verificacion de identidad

La AR verifica la identidad del solicitante antes de tramitar cualquier solicitud de certificado. El metodo de verificacion determina el nivel de aseguramiento (LoA) conforme a eIDAS y, consecuentemente, el tipo de certificado que puede emitirse.

3.1.1 Verificación presencial (LoA High)

Requisitos previos: - Oficina AR habilitada conforme a GOYA-PS02-001. - Operador AR con capacitación vigente en verificación presencial. - Equipamiento: escáner de documentos, lector biométrico, estación de trabajo segura.

Procedimiento:

1. El solicitante se presenta en la oficina AR con su documento de identidad vigente (cedula de identidad o pasaporte).
2. El operador AR verifica la vigencia del documento consultando la fecha de expiración impresa.
3. El operador AR compara visualmente la fotografía del documento con la persona presente, verificando correspondencia facial.
4. El operador AR escanea el anverso y reverso del documento a resolución mínima de 300 DPI.
5. Si el documento dispone de chip NFC (pasaportes e-MRTD, cédulas electrónicas), el operador lee el chip mediante lector NFC certificado y verifica la autenticidad del chip (BAC/PACE).
6. El operador AR captura la evidencia biométrica del solicitante (huella dactilar) conforme a ISO 19794-2 mediante el lector biométrico.
7. El operador AR registra la verificación en el sistema mediante POST /api/v1/identity/verify con los siguientes datos:
 - method: InPerson
 - jurisdiction: jurisdicción del solicitante (CL, EU, AE)
 - national_id: identificador nacional (RUT, National ID, Emirates ID)
 - legal_name: nombre legal conforme al documento
 - biometric_hash: hash SHA-256 de la evidencia biométrica capturada
8. El sistema genera un IdentityProofing con estado Pending.
9. El operador AR revisa la consistencia de los datos ingresados y aprueba la verificación.
10. El sistema actualiza el estado a Verified y asigna loa: High.
11. El operador AR entrega al solicitante un comprobante de verificación con el número de referencia.

Documentación retenida: copia digitalizada del documento, registro biométrico (hash), grabación de la sesión (si aplica), formulario de consentimiento firmado. Periodo de retención: 15 años conforme a DS 181/2002 Art. 25.

3.1.2 Verificación por videoconferencia (LoA Substantial)

Requisitos previos: - Plataforma de videoconferencia con cifrado extremo a extremo. - Operador AR con capacitación vigente en verificación remota. - Resolución mínima de video: 720p. - Grabación obligatoria de la sesión con sellado de tiempo.

Procedimiento:

1. El solicitante agenda una sesión de videoconferencia a través del portal de la AR.
2. El sistema genera un enlace de sesión único con token de autenticación y vigencia de 24 horas.
3. El solicitante se conecta a la sesión e inicia la verificación con el operador AR.

4. El operador AR solicita al solicitante que muestre su documento de identidad ante la cámara:
 - Anverso: nombre completo, fotografía, número de documento.
 - Reverso: datos adicionales, código de barras o MRZ.
5. El operador AR verifica la correspondencia facial entre la persona en pantalla y la fotografía del documento.
6. El operador AR aplica prueba de vida (liveness detection):
 - Solicita al solicitante que gire la cabeza a la izquierda y derecha.
 - Solicita al solicitante que parpadee.
 - Verifica que no se trate de una imagen estática o video pregrabado.
7. Si el documento dispone de chip NFC y el solicitante posee un dispositivo NFC, se realiza lectura remota asistida.
8. El operador AR registra la verificación en el sistema mediante `POST /api/v1/identity/verify` con `method: VideoConference`.
9. El sistema graba la sesión, asocia el sellado de tiempo TSA y almacena el registro.
10. El estado se actualiza a `Verified` con `loa: Substantial`.

Documentación retenida: grabación de la sesión de video con sellado de tiempo, capturas del documento, registro de prueba de vida. Periodo de retención: 15 años.

3.1.3 Verificación remota via Smart-ID (LoA High)

Requisitos previos: - Integración activa con SK ID Solutions (servicio Smart-ID). - Suscriptor con cuenta Smart-ID vinculada a identidad electrónica estonia. - Disponibilidad del servicio Smart-ID verificada.

Procedimiento:

1. El solicitante inicia el proceso de verificación desde el portal o la aplicación de escritorio Goya Ledger.
2. El sistema envía una solicitud de autenticación a `POST /api/v1/identity/verify` con los siguientes parámetros:
 - `method: SmartId`
 - `jurisdiction: EU`
 - `national_id`: código de identidad personal estonia
 - `smart_id_session`: identificador de sesión Smart-ID
3. El servidor inicia una sesión de autenticación contra la API de SK ID Solutions.
4. Smart-ID envía una notificación push al dispositivo móvil del solicitante con un código de verificación de 4 dígitos.
5. El solicitante verifica el código de verificación mostrado en pantalla y confirma con su PIN Smart-ID (PIN1 para autenticación).
6. SK ID Solutions devuelve el resultado de la autenticación con el certificado de autenticación del titular.
7. El sistema verifica:
 - Validez del certificado de autenticación (cadena de confianza, vigencia, estado de revocación vía OCSP).
 - Correspondencia del nombre en el certificado con los datos declarados.
 - Hash de la sesión de autenticación.
8. Si la verificación es exitosa, el sistema actualiza el `IdentityProofing` a estado `Verified` con `loa: High`.
9. El sistema genera el DID del suscriptor en formato `did:goya:`
`{pubkey_hex[..16]}` mediante `identity::did::did_from_pubkey_hex()`.

10. Si la verificación falla, el estado se establece en Rejected con la razón correspondiente (certificate_expired, signature_invalid, user_cancelled).

Mapeo de niveles de aseguramiento eIDAS:

Metodo Smart-ID	Nivel eIDAS	Nivel AR Goya	Tipos de certificado habilitados
Smart-ID Qualified	High	High	FEA, certificados cualificados
Smart-ID Basic	Substantial	Substantial	FEA con restricciones

Documentación retenida: registro de sesión Smart-ID, resultado de autenticación, certificado de autenticación del titular (copia pública), sellado de tiempo. Periodo de retención: 15 años.

3.1.4 Tabla resumen de niveles de aseguramiento

Metodo de verificación	LoA eIDAS	Tipo certificado	Algoritmo firma
Presencial (cedula + biometría)	High	FEA cualificado	ML-DSA-65
Presencial (cedula sin biometría)	High	FEA avanzado	ML-DSA-65 / Ed25519
Videoconferencia con operador	Substantial	FEA avanzado	ML-DSA-65 / Ed25519
Smart-ID Qualified	High	FEA cualificado	ML-DSA-65
Smart-ID Basic	Substantial	FEA avanzado	Ed25519

3.2 Verificación de RUT (Chile)

La verificación del Rol Único Tributario (RUT) es obligatoria para solicitantes de jurisdicción chilena. El procedimiento complementa la verificación de identidad de la sección 3.1.

Procedimiento:

1. El operador AR (o el sistema en verificaciones automatizadas) recibe el RUT declarado por el solicitante en formato XX.XXX.XXX-D.
2. El sistema ejecuta la validación de formato y dígito verificador mediante la función `validate_rut()`:
 - Verifica que el cuerpo numérico contenga entre 7 y 8 dígitos.
 - Calcula el dígito verificador mediante algoritmo Módulo 11.
 - Compara el dígito calculado con el dígito declarado.
3. El sistema consulta el registro del SII para verificar:
 - Existencia del RUT en el registro de contribuyentes.
 - Estado del contribuyente (activo, inactivo, suspendido).
 - Nombre o razón social asociada al RUT.

4. El operador AR cruza la informacion del SII con los datos del documento de identidad presentado:
 - El nombre registrado en el SII debe coincidir con el nombre del documento de identidad.
 - El RUT del documento debe coincidir con el RUT consultado.
5. En caso de discrepancia entre el nombre del SII y el documento de identidad (por cambio de nombre legal, errores de transcripcion o uso de nombres compuestos), el operador AR escala al Gerente de Operaciones AR para resolucioⁿ conforme a la seccion 3.4.
6. El resultado de la verificacioⁿ de RUT se registra en el campo `national_id_verified` del IdentityProofing.

Registros de evidencia: captura de la consulta al SII, resultado de validacioⁿ Modulo 11, comparacioⁿ de nombres.

3.3 Autenticacion del solicitante

La autenticacion del solicitante complementa la verificacioⁿ de identidad y confirma que la persona que solicita el certificado es la misma que fue verificada.

Mecanismos de autenticacion por metodo:

Metodo de verificacio ⁿ	Mecanismo primario	Mecanismo secundario
Presencial	Presencia fisica + documento	OTP via SMS al numero registrado
Videoconferencia	Sesio ⁿ en vivo + documento	OTP via correo electronico
Smart-ID	PIN1 Smart-ID (autenticacio ⁿ)	Verificacio ⁿ de codigo de 4 digitos

Procedimiento de autenticacion challenge-response:

1. El sistema genera un desafio aleatorio (challenge) de 32 bytes mediante el generador criptografico de `crates/pqc_crypto_module/`.
2. El sistema envia el desafio al solicitante a traves del canal correspondiente:
 - Presencial: se muestra en la estacioⁿ de trabajo del operador AR.
 - Videoconferencia: se muestra en pantalla compartida.
 - Smart-ID: se envia como parte de la sesioⁿ de autenticacioⁿ.
3. El solicitante firma el desafio con su clave privada (si ya dispone de par de llaves) o confirma mediante OTP.
4. El sistema verifica la respuesta:
 - Firma: verificacioⁿ criptografica mediante `verify_signature()`.
 - OTP: comparacioⁿ del codigo ingresado con el codigo generado (vigencia 5 minutos, uso unico).
5. El resultado de la autenticacioⁿ se registra en el IdentityProofing.

OTP via SMS: - Codigo numerico de 6 digitos. - Vigencia: 5 minutos desde la emision. - Maximo 3 intentos fallidos antes de bloqueo temporal (30 minutos). - El numero de telefono movil debe coincidir con el registrado en la solicitud.

OTP via correo electronico: -Codigo alfanumerico de 8 caracteres. - Vigencia: 15 minutos desde la emision. - Maximo 3 intentos fallidos antes de bloqueo temporal (30 minutos).

3.4 Verificacion de nombre segun politica

La AR verifica que el nombre del suscriptor en la solicitud de certificado coincida con el nombre en el documento de identidad y con el nombre registrado en la Politica de Certificados (GOYA-PO01-001, seccion 3.1).

Reglas de coincidencia de nombres:

1. **Coincidencia exacta:** el nombre en la solicitud debe coincidir caracter por caracter con el nombre en el documento de identidad, respetando mayusculas y minusculas del documento.
2. **Diacriticos:** los caracteres con diacriticos (acentos, tilde, dieresis) se consideran equivalentes a sus versiones sin diacriticos para efectos de comparacion, pero el certificado emitido debe contener la version con diacriticos del documento de identidad.
3. **Transliteracion:** para documentos emitidos en alfabetos no latinos, el nombre se translitera conforme a ISO 9 (cirilico) o UNGEGN (arabe) y se registra tanto la version original como la transliterada.
4. **Nombres compuestos:** se aceptan variaciones en el orden de nombres y apellidos conforme a la convencion local:
 - Chile: nombre(s) + apellido paterno + apellido materno.
 - EU: conforme al certificado de identidad electronica.
 - UAE: conforme al Emirates ID.
5. **Abreviaciones:** no se aceptan abreviaciones del nombre. El nombre completo del documento de identidad es obligatorio.
6. **Discrepancias:** cualquier discrepancia que no se resuelva mediante las reglas anteriores requiere:
 - Presentacion de documentacion adicional (certificado de cambio de nombre, sentencia judicial).
 - Aprobacion del Gerente de Operaciones AR.
 - Registro de la excepcion en la bitacora de incidencias.

4. Entrega Segura de Datos de Creacion de Firma

4.1 Generacion de llaves del suscriptor

La generacion del par de llaves criptograficas del suscriptor constituye un evento critico que debe realizarse bajo condiciones controladas conforme a GOYA-PS06-001.

Algoritmos soportados:

Algoritmo	Nivel	Uso principal	Tamano firma
ML-DSA-65	Post-cuantico	FEA cualificada	3309 bytes
Ed25519	Clasico	FES, FEA avanzada	64 bytes

Algoritmo	Nivel	Uso principal	Tamano firma
SLH-DSA-128s	Post-cuantico	Certificados de larga duracion	Variable

Modalidades de generacion:

1. Generacion en dispositivo del suscriptor (preferida):

- El suscriptor genera el par de llaves en su SSCD/QSCD o en su dispositivo local.
- La clave privada nunca abandona el dispositivo del suscriptor.
- El suscriptor exporta unicamente la clave publica para la solicitud de certificado.
- La AR verifica que la clave publica corresponda al algoritmo solicitado y cumpla los parametros de seguridad.

2. Generacion asistida por la AR:

- En casos donde el suscriptor no dispone de capacidad de generacion local, la AR genera el par de llaves en un HSM certificado.
- La clave privada se exporta en formato PKCS#12 cifrado con contraseña de transporte.
- La contraseña de transporte se genera aleatoriamente (minimo 20 caracteres alfanumericos) y se entrega al suscriptor por canal separado (sobre sellado en verificacion presencial, SMS cifrado en verificacion remota).
- La AR destruye toda copia de la clave privada inmediatamente despues de la exportacion PKCS#12.

4.2 Transporte PKCS#12

Cuando se utiliza la modalidad de generacion asistida, el archivo PKCS#12 se entrega al suscriptor conforme al siguiente procedimiento:

1. El HSM genera el par de llaves y exporta el archivo PKCS#12 cifrado con AES-256.
2. La contraseña de cifrado se divide en dos mitades mediante esquema de conocimiento dividido (split knowledge):
 - Primera mitad: entregada por el operador AR en persona o via canal cifrado.
 - Segunda mitad: enviada por SMS al numero de telefono verificado del suscriptor.
3. El archivo PKCS#12 se entrega por canal cifrado (HTTPS con TLS 1.3 minimo).
4. El suscriptor descarga el archivo PKCS#12, importa las llaves a su SSCD/QSCD e introduce ambas mitades de la contraseña.
5. El suscriptor confirma la recepcion y la capacidad de firma mediante una operacion de firma de prueba.
6. La AR registra la entrega exitosa y destruye el archivo PKCS#12 del almacenamiento temporal.

4.3 Datos de activacion

Dato	Metodo de entrega	Canal	Vigencia
	Sobre sellado / SMS cifrado		

Dato	Metodo de entrega	Canal	Vigencia
PIN de firma (PIN2)		Separado de PKCS#12	Hasta primer uso (cambio obligatorio)
Contrasena PKCS#12 (mitad 1)	Entrega directa del operador AR	Presencial / canal cifrado	24 horas
Contrasena PKCS#12 (mitad 2)	SMS al numero verificado	SMS	24 horas
Codigo de desbloqueo (PUK)	Sobre sellado	Correo postal certificado / presencial	Sin expiracion

5. Dispositivo Seguro de Firma

5.1 Requisitos del SSCD/QSCD

Para la emision de certificados cualificados (FEA cualificada, LoA High), el suscriptor debe utilizar un dispositivo seguro de creacion de firma que cumpla:

Requisito	Norma	Descripcion
Certificacion de dispositivo	EN 419211 o FIPS 140-2 Nivel 2+	El dispositivo debe contar con certificacion vigente
Control exclusivo del titular	DS 181/2002 Art. 5	Solo el titular puede activar la clave privada
Proteccion de clave privada	eIDAS Art. 29	La clave privada no es extraible del dispositivo
Resistencia a manipulacion	EN 419211-2	El dispositivo resiste ataques fisicos y logicos

5.2 Mecanismos de proteccion

Control de acceso al dispositivo:

1. **PIN de firma (PIN2):** requerido para cada operacion de firma. Longitud minima 6 digitos. El suscriptor define su PIN en el primer uso.
2. **PIN de autentificacion (PIN1):** requerido para operaciones de autentificacion. Longitud minima 4 digitos.
3. **Biometria:** opcionalmente, el dispositivo puede protegerse mediante huella dactilar o reconocimiento facial conforme a ISO 19794-2, siempre como complemento al PIN (autentificacion de dos factores).

Política de bloqueo:

Evento	Accion	Desbloqueo
3 intentos fallidos de PIN1	Bloqueo de autenticacion	Ingreso de PUK
3 intentos fallidos de PIN2	Bloqueo de firma	Ingreso de PUK
3 intentos fallidos de PUK	Bloqueo permanente del dispositivo	Revocacion del certificado + emision de nuevo dispositivo
Reporte de perdida o robo	Bloqueo remoto inmediato	Revocacion del certificado

5.3 Borrado remoto

En caso de perdida, robo o compromiso del dispositivo, la AR puede ejecutar un borrado remoto de las credenciales:

1. El suscriptor reporta la perdida/robo a la AR mediante los canales de soporte (seccion 6.3).
2. El operador AR verifica la identidad del solicitante mediante el procedimiento de autenticacion de la seccion 3.3.
3. El operador AR ejecuta la suspension inmediata del certificado asociado (seccion 7.1).
4. Si el dispositivo soporta gestion remota (MDM), el operador AR emite la orden de borrado remoto.
5. El operador AR inicia el procedimiento de revocacion del certificado (seccion 7.2).
6. Se registra el evento en la bitacora de incidencias conforme a GOYA-PS07-001.

6. Capacitacion y Soporte al Titular

6.1 Programa de incorporacion del suscriptor

Al completar la verificacion de identidad y la emision del certificado, el suscriptor recibe una sesion de incorporacion que incluye:

- 1. Introduccion al certificado digital:**
 - Estructura del certificado X.509 y campos relevantes.
 - Diferencia entre FES (Ed25519) y FEA (ML-DSA-65).
 - Periodo de validez y proceso de renovacion.
- 2. Uso del certificado:**
 - Firma de documentos electronicos.
 - Autenticacion en servicios que aceptan certificados Goya Ledger.
 - Verificacion de firmas de terceros.
- 3. Seguridad del dispositivo:**
 - Custodia del SSCD/QSCD.
 - Politica de PIN: no compartir, no anotar, cambiar periodicamente.
 - Actualizacion de firmware del dispositivo.
- 4. Procedimientos de emergencia:**
 - Suspension temporal del certificado.
 - Revocacion definitiva.

- Reporte de perdida o robo del dispositivo.

6.2 Material de referencia entregado al suscriptor

Documento	Formato	Contenido
Guia rapida de uso del certificado	PDF	Procedimientos basicos de firma y autenticacion
Politica de certificados (extracto publico)	PDF / Web	Derechos y obligaciones del suscriptor
Procedimiento de revocacion	PDF	Pasos para revocar el certificado
Acuerdo de suscriptor	PDF firmado	Terminos y condiciones de uso
Contactos de soporte	PDF / Web	Canales y horarios de atencion

6.3 Canales de soporte

Canal	Horario	Tiempo de respuesta (SLA)	Uso
Correo electronico (soporte@goya-ledger.cl)	24/7	4 horas habiles	Consultas generales, solicitudes de cambio
Telefono (+56 2 XXXX XXXX)	Lun-Vie 09:00-18:00 CLT	Inmediato	Consultas urgentes, soporte tecnico
Portal web de autoservicio	24/7	Autoservicio	Estado del certificado, descarga de CRL
Linea de emergencia (revocacion)	24/7	15 minutos	Reporte de compromiso, perdida, robo

Acuerdos de nivel de servicio (SLA):

Servicio	SLA	Metrica
Verificacion de identidad presencial	Completada en la misma sesion	95% de las solicitudes
Verificacion de identidad por Smart-ID	Resultado en 5 minutos	99% de las solicitudes
Suspension de certificado (emergencia)	Efectiva en 15 minutos	100% de las solicitudes
Revocacion de certificado		99% de las solicitudes

Servicio	SLA	Metrica
	Efectiva en 1 hora	
Actualizacion de CRL post-revocacion	En 60 minutos	100% de los eventos
Actualizacion de OCSP post-revocacion	En 10 minutos	100% de los eventos

7. Procedimientos de Suspension y Revocacion

7.1 Suspension de certificado

La suspension inhabilita temporalmente un certificado sin revocar su validez de forma definitiva.

Causas de suspension:

Codigo	Causa	Solicitante autorizado
S01	Sospecha de compromiso de clave privada	Suscriptor, Oficial de Seguridad
S02	Perdida temporal del dispositivo	Suscriptor
S03	Solicitud del suscriptor sin expresion de causa	Suscriptor
S04	Orden judicial	Gerente General (previa verificacion legal)
S05	Investigacion de uso indebido	Oficial de Seguridad

Procedimiento:

1. El solicitante contacta a la AR mediante cualquier canal de soporte (seccion 6.3).
2. El operador AR verifica la identidad del solicitante conforme a la seccion 3.3.
3. El operador AR registra la solicitud de suspension con el codigo de causa.
4. El operador AR ejecuta la suspension mediante `POST /api/v1/certificates/fea/revoke` con el parametro `action: suspend` y el DID del suscriptor.
5. El sistema actualiza el estado del certificado a `Suspended` en el almacenamiento RocksDB.
6. El sistema dispara la actualizacion de la CRL y del respondedor OCSP.

7. El operador AR notifica al suscriptor la efectividad de la suspension por correo electronico y SMS.
8. La suspension tiene una vigencia maxima de 30 dias. Transcurrido ese plazo sin reactivacion, el certificado se revoca automaticamente.

Reactivacion:

1. El suscriptor solicita la reactivacion contactando a la AR.
2. El operador AR verifica la identidad del solicitante.
3. Si la causa de suspension fue S01 (sospecha de compromiso), el Oficial de Seguridad debe autorizar la reactivacion tras investigacion.
4. El operador AR reestablece el estado del certificado y actualiza la CRL y OCSP.

7.2 Revocacion de certificado

La revocacion inhabilita definitiva e irreversiblemente un certificado.

Causas de revocacion (RFC 5280 seccion 5.3.1):

Codigo RFC 5280	Causa	Descripcion
0	unspecified	Razon no especificada
1	keyCompromise	Compromiso confirmado de clave privada
2	cACompromise	Compromiso de la AC (tratado en GOYA-AD01-001)
3	affiliationChanged	Cambio de afiliacion del suscriptor
4	superseded	Certificado reemplazado por uno nuevo
5	cessationOfOperation	Cese de operaciones del suscriptor
6	certificateHold	Suspension (ver seccion 7.1)
9	privilegeWithdrawn	Retiro de privilegios

Procedimiento:

1. El solicitante contacta a la AR mediante cualquier canal de soporte.
2. El operador AR verifica la identidad del solicitante conforme a la seccion 3.3.
3. El operador AR registra la solicitud de revocacion con el codigo de causa RFC 5280.
4. Para revocaciones por compromiso de clave (codigo 1), el operador AR escala inmediatamente al Oficial de Seguridad y ejecuta la revocacion sin esperar aprobacion adicional.
5. El operador AR ejecuta la revocacion mediante `POST /api/v1/certificates/fea/revoke` con el DID del suscriptor y el codigo de causa.
6. El sistema actualiza el estado del certificado a Revoked con la marca temporal de revocacion.
7. El sistema dispara la publicacion de una nueva CRL conforme al siguiente cronograma:

Prioridad	Causa	Publicacion CRL	Actualizacion OSCP
Critica	keyCompromise (1), cACompromise (2)	Inmediata (< 15 min)	Inmediata (< 5 min)
Alta	cessationOfOperation (5), privilegeWithdrawn (9)	En 1 hora	En 10 minutos
Normal	Resto de causas	En la siguiente emision programada (cada 4 horas)	En 30 minutos

1. El operador AR notifica al suscriptor la efectividad de la revocacion por correo electronico y SMS.
2. La revocacion es irreversible. Si el suscriptor requiere un nuevo certificado, debe iniciar un nuevo proceso de registro (seccion 3).

Plazos de gracia:

Solicitud	Plazo de gracia	Accion durante el plazo
Revocacion por el suscriptor (causas 0, 3, 4, 5)	24 horas para cancelar antes de publicacion en CRL	Certificado marcado internamente, no publicado en CRL hasta vencer el plazo
Revocacion por compromiso (causa 1)	Sin plazo de gracia	Publicacion inmediata en CRL y OSCP
Revocacion por orden judicial (causa 9)	Sin plazo de gracia	Publicacion inmediata en CRL y OSCP

8. Interaccion AR-AC

8.1 Flujo de reenvio de CSR

La AR actua como intermediario entre el suscriptor y la AC para la emision de certificados. El flujo operativo es el siguiente:

1. El operador AR completa la verificacion de identidad (seccion 3.1) y obtiene un IdentityProofing con estado Verified.
2. El suscriptor genera su par de llaves y entrega la clave publica a la AR (seccion 4.1).
3. La AR construye la solicitud de certificado (CSR) incluyendo:
 - Clave publica del suscriptor.

- DID del suscriptor (`did:goya:{pubkey_hex[. .16]}`).
 - Nivel de aseguramiento determinado (LoA).
 - Algoritmo de firma solicitado (ML-DSA-65 o Ed25519).
 - Datos del sujeto (nombre legal, jurisdiccion, identificador nacional).
4. La AR envia la solicitud a la AC mediante `POST /api/v1/certificates/fea` con el CSR y el identificador del IdentityProofing.
 5. La AC verifica:
 - Existencia y validez del IdentityProofing referenciado.
 - Consistencia entre los datos del CSR y el IdentityProofing.
 - Conformidad de la clave publica con la politica de certificados (GOYA-PO01-001).
 6. La AC emite el certificado y lo firma con la clave de la AC Intermedia.
 7. La AC devuelve el certificado emitido a la AR.
 8. La AR entrega el certificado al suscriptor y registra la emision en su bitacora.

8.2 Transmision de resultados de verificacion de identidad

Campo transmitido	Tipo	Descripcion
proofing_id	UUID	Identificador unico de la verificacion
did	String	DID del suscriptor verificado
status	Enum	Verified / Rejected
method	Enum	Metodo de verificacion utilizado
loa	Enum	Low / Substantial / High
jurisdiction	String	CL / EU / AE
national_id_hash	String	Hash SHA-256 del identificador nacional
verified_at	DateTime	Marca temporal de la verificacion (UTC)
operator_id	String	Identificador del operador AR que ejecuto la verificacion

La transmision se realiza mediante canal cifrado TLS 1.3 entre la AR y la AC. Cada transmision se sella con marca temporal TSA y se registra en la bitacora de auditoria.

8.3 Reenvio de solicitudes de revocacion

Cuando la AR recibe una solicitud de revocacion, la reenvia a la AC conforme al siguiente flujo:

1. La AR verifica la identidad del solicitante y registra la solicitud (seccion 7.2).
2. La AR transmite la solicitud de revocacion a la AC incluyendo: DID del certificado, codigo de causa RFC 5280 y evidencia de verificacion de identidad.
3. La AC ejecuta la revocacion, actualiza la CRL y el respondedor OCSP.
4. La AC confirma la revocacion a la AR.

5. La AR notifica al suscriptor.

8.4 Bitacora de auditoria

Toda interaccion AR-AC se registra en la bitacora de auditoria con los siguientes campos:

Campo	Descripcion
timestamp	Marca temporal UTC del evento
event_type	csr_submitted, cert_issued, revocation_requested, revocation_confirmed
actor	Identificador del operador AR o proceso automatizado
target_did	DID del suscriptor afectado
request_hash	Hash SHA-256 del contenido de la solicitud
response_hash	Hash SHA-256 de la respuesta de la AC
trace_id	Identificador de traza para correlacion con logs de la AC

La bitacora se almacena en RocksDB cuando STORAGE_BACKEND=rocksdb y se respalda conforme a GOYA-PS03-001. La retencion minima es de 15 anios conforme a DS 181/2002.

8.5 Acuerdos de nivel de servicio AR-AC

Operacion	SLA	Metrica
Emision de certificado tras CSR valido	5 minutos	99% de las solicitudes
Revocacion tras solicitud AR	15 minutos	100% de las solicitudes
Disponibilidad del servicio AC para la AR	99.5% mensual	Medido por health check
Notificacion de incidentes AC a AR	30 minutos	100% de los incidentes

9. Contingencias

9.1 Referencia al plan de continuidad

Los procedimientos de contingencia de la AR se rigen por GOYA-PS03-001 (Plan de Continuidad del Negocio). La presente seccion describe los escenarios especificos de la AR y las acciones inmediatas a ejecutar.

9.2 Falla del sistema AR

Escenario: indisponibilidad del sistema de verificación de identidad o del API de la AR.

Paso	Acción	Responsable	Plazo
1	Detectar la falla mediante monitoreo automatizado (health check cada 60 segundos)	Sistema de monitoreo	Automatico
2	Notificar al Gerente de Operaciones AR y al Oficial de Seguridad	Sistema de alertas	5 minutos
3	Activar página de estado indicando indisponibilidad del servicio	Operador AR	15 minutos
4	Evaluar si la falla afecta la seguridad de llaves o datos de suscriptores	Oficial de Seguridad	30 minutos
5	Si la falla no compromete seguridad: restaurar desde backup conforme a GOYA-PS03-001	Gerente Ops AR	2 horas
6	Si la falla compromete seguridad: activar procedimiento de incidentes GOYA-PS07-001	Oficial de Seguridad	Inmediato
7	Reanudar operaciones y verificar integridad de datos	Gerente Ops AR	Post-restauración

Medidas durante la indisponibilidad: - Las solicitudes de verificación presencial se registran en formularios físicos y se ingresan al sistema una vez restaurado. - Las solicitudes de revocación de emergencia se procesan mediante comunicación directa con la AC (GOYA-AD01-001). - Las solicitudes de certificados nuevos se suspenden hasta la restauración del sistema.

9.3 Indisponibilidad del servicio Smart-ID

Escenario: el servicio de SK ID Solutions no responde o devuelve errores sistemáticos.

Paso	Acción	Responsable	Plazo
1	Detectar la indisponibilidad mediante timeout de la API Smart-ID (> 30 segundos)	Sistema AR	Automatico
2	Reintentar la solicitud hasta 3 veces con backoff exponencial (5s, 15s, 45s)	Sistema AR	2 minutos
3	Si los reintentos fallan, notificar al solicitante la indisponibilidad temporal	Sistema AR	Automatico
4	Ofrecer al solicitante método alternativo de verificación (videoconferencia)	Operador AR	15 minutos
5	Registrar la incidencia en el sistema de gestión de incidentes	Operador AR	30 minutos
6	Monitorear el estado del servicio Smart-ID hasta su restauración	Sistema de monitoreo	Continuo
7	Procesar solicitudes pendientes una vez restaurado el servicio	Sistema AR	Post-restauración

Fallback para verificaciones Smart-ID: - Verificación por videoconferencia con operador AR (LoA Substantial en lugar de High). - Si el suscriptor requiere LoA High, debe esperar a la restauración del servicio Smart-ID o acudir a verificación presencial.

9.4 Indisponibilidad de la comunicación AR-AC

Escenario: la AR no puede comunicarse con la AC para reenviar CSR o solicitudes de revocación.

1. La AR almacena localmente las solicitudes pendientes en una cola persistente (RocksDB).
 2. La AR continúa aceptando y procesando verificaciones de identidad.
 3. La emisión de certificados se suspende hasta la restauración de la comunicación con la AC.
 4. Las solicitudes de revocación de emergencia se comunican a la AC por canal alternativo (teléfono, correo electrónico cifrado) conforme a GOYA-AD01-001.
 5. Una vez restaurada la comunicación, la AR procesa la cola de solicitudes pendientes en orden cronológico.
-

10. Referencias

10.1 Documentos internos

ID	Documento
GOYA-PS01-001	Plan de Gestión de Riesgos
GOYA-PS02-001	Política de Seguridad
GOYA-PS03-001	Plan de Continuidad del Negocio
GOYA-PS04-001	Plan del SGSI
GOYA-PS05-001	Autoevaluación de Cumplimiento
GOYA-PS06-001	Plan de Administración de Llaves
GOYA-PS07-001	Plan de Cese de Actividades
GOYA-PO01-001	Política de Certificados FEA
GOYA-PO03-001	Modelo Operacional AC
GOYA-PO04-001	Modelo Operacional AR
GOYA-AD01-001	Manual de Operaciones AC
GOYA-CPS-001	Declaración de Prácticas de Certificación (CPS)

10.2 Normativa chilena

Norma	Descripción
Ley 19.799	Ley sobre documentos electrónicos, firma electrónica y servicios de certificación
DS 181/2002	Reglamento de la Ley 19.799

Norma	Descripcion
NCh-ISO 27001	Sistema de gestion de seguridad de la informacion

10.3 Normativa y estandares internacionales

Norma	Descripcion
eIDAS (Reglamento UE 910/2014)	Marco europeo de identificacion electronica y servicios de confianza
EA-103 v2.1	Guia de evaluacion para PSC (seccion 4.22: operaciones AR)
RFC 5280	Internet X.509 PKI Certificate and CRL Profile
RFC 6960	X.509 Internet PKI Online Certificate Status Protocol (OCSP)
RFC 3647	Internet X.509 PKI Certificate Policy and Certification Practices Framework
ISO 19794-2	Biometric data interchange formats – Finger minutiae data
EN 419211	Protection profiles for secure signature creation device
FIPS 140-2	Security requirements for cryptographic modules
FIPS 203	ML-KEM (Module-Lattice-Based Key-Encapsulation Mechanism)
FIPS 204	ML-DSA (Module-Lattice-Based Digital Signature Algorithm)

10.4 Especificaciones tecnicas externas

Especificacion	Descripcion
Smart-ID Technical Specification	Protocolo de autentificacion e identidad electronica de SK ID Solutions
PKCS#11 v2.40	Cryptographic Token Interface Standard
PKCS#12 v1.1	Personal Information Exchange Syntax Standard

Fin del documento AD02 – Manual de Operaciones de la Autoridad de Registro (AR)